



MICROSOFT EMS COMMUNITY

WELCOME TO

The hidden risk with the guest in your tenant

FRI • 05/09/2026

Entra ID

Talk by Victor Nazmi

TODAY'S SPEAKER

Victor Nazmi

Security Operations Specialist (SecOps) @ Abacus Medicine Group

- *Community-driven security contributor - Started the Cyber Security journey as a CTF player in 2019.*
- *Today SecOps Specialist - Technical responsible for IT & OT Security*
- *I like to research within Microsoft suite and test Private preview*

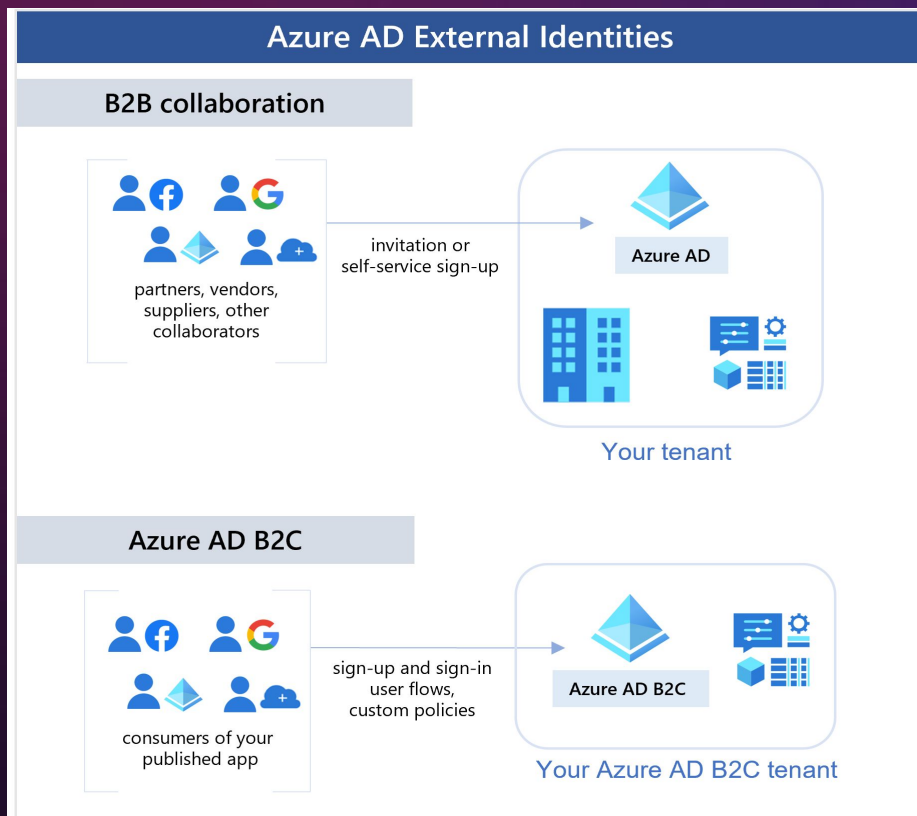
n0zk.com

Hosted by Microsoft EMS Discord Staff Team



Feeling the temperature in the room

What's an Guest?



Last time you checked for an Guest?

Search users

User type == Guest

420 users found

	Display name ↑		User principal
☐	[blurred]	Guest	No No ExternalAzureAD
☐	[blurred]	Guest	No No ExternalAzureAD
☐	[blurred]	Guest	No No MicrosoftAccount
☐	[blurred]	Guest	No No ExternalAzureAD
☐	[blurred]	Guest	No No ExternalAzureAD

The risk hidden with “guests”

Who doesn't love guests?



Easily invited

Invites to everyone – also neighbor company!!



Missing control

We forgot about they still exists in the tenant



Brings unexpected resources

Ready for new subscription?

Easily invited

Invites to everyone – also neighbor company!



Guest invite

Anyone can invite guest users – Default?



Guests can invite other Guests?

Having an Guest? – Let's invite another as well.



Admin? We don't need them

Non-admins are able to invite



Domain Restrictions

Domain restrictions has left the room – Any domain can join!



Missing control

We forgot about they still exists in the tenant



All users group

Why not for everyone when we can?



Dynamic groups

I'm loving it (Dynamic groups)



Access to everyone

Sometimes we like to make "minor" changes



Free access forever?

They are guests – let them be as they are!



Brings unexpected resources

Ready for new subscription?



Billing role

The underrated Entra role



Billing Permissions

User with Billing role can create subscriptions?



Home tenant vs “Guest” tenant

The Guest tenant may be the new Resource tenant



Moving bits around

What if we move subscriptions?

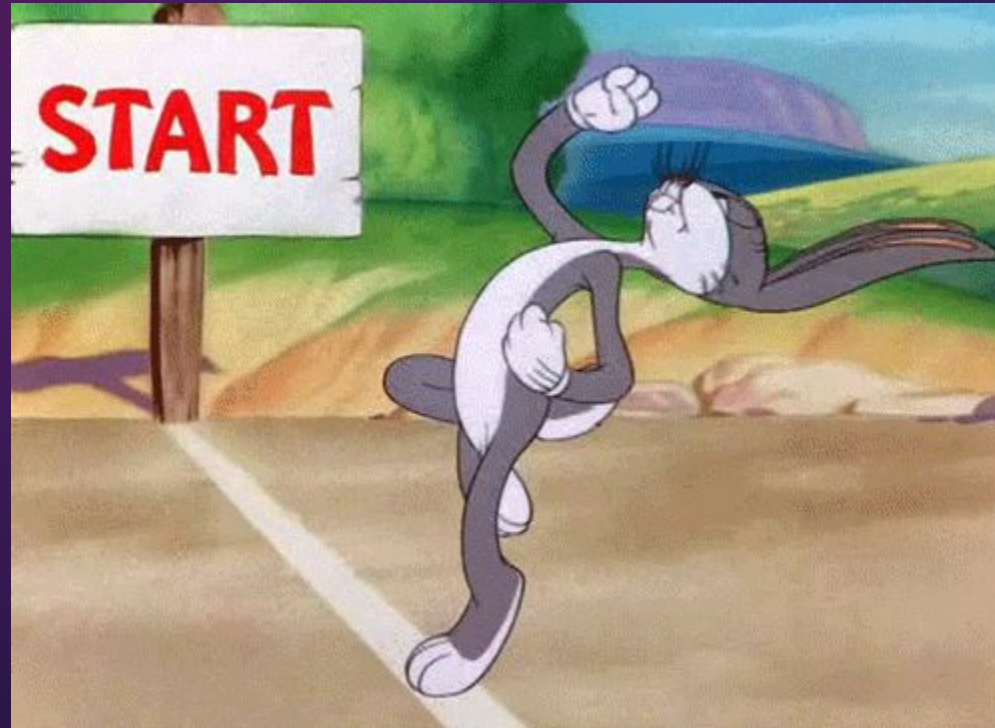


After reading Beyondtrust's article

Kudos to Simon and the team for great research

Where do we start ?

Key takeaway points!



Easily invited

Invites to everyone – also neighbor company!

Guest invite settings

Guest invite restrictions ⓘ

[Learn more](#)

- ☒ Anyone in the organization can invite guest users including guests and non-admins (most inclusive)
- ☐ Member users and users assigned to specific admin roles can invite guest users including guests with member permissions
- ☐ Only users assigned to specific admin roles can invite guest users
- ☐ No one in the organization can invite guest users including admins (most restrictive)

Identity > External Identities > External collaboration settings in the Microsoft Entra admin center.

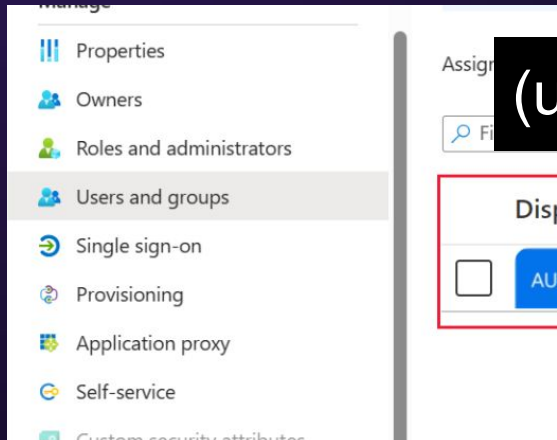
Collaboration restrictions

⚠ Cross-tenant access settings are also evaluated when sending an invitation to determine whether the invite should be allowed or blocked. [Learn more.](#)

- ☒ Allow invitations to be sent to any domain (most inclusive)
- ☐ Deny invitations to the specified domains
- ☐ Allow invitations only to the specified domains (most restrictive)

Missing control

We forgot about they still



PREPARE YOURSELF

AN AUDIT IS COMING

Review type | **Reviews** | **Settings** | **Review + Create**

Schedule an access review to ensure the right people have the right access to access packages, groups, apps, and privileged roles.
[Learn more](#)

Select what to review * Teams + Groups

365 groups with guest users ⓘ
+ groups

only

Settings | **Review + Create**

ings, including decision helpers and email notifications.

Settings

Source ⓘ ☒
Remove access

don't respond' to 'Remove access' or 'Take recommendations' results to resource' is enabled could potentially lead to all access being revoked if the reviewers fail to respond.

Guest users ⓘ Block user from signing-in for 30 ...

Notification to + Select User(s) or Group(s)

Decision helpers

ⓘ ☒
 ⓘ ☒

 ⓘ ☒
 ⓘ ☒
 ⓘ ☒

Additional content for reviewer email ⓘ Please review whether or not you still need access.

< Previous Next: Review + Create

Brings unexpected resources

Ready for new subscription?

 External Id

 Feedback

Overview

Cross-tenant access sett

All identity providers

External collaboration s

Diagnose and solve pro

> Self-service sign up

> Subscriptions

> Lifecycle management

Subscriptions | Manage policies

Configure policy settings for Azure subscription operations.

Subscription leaving Microsoft Entra tenant:

This policy controls if users can change the Microsoft Entra tenant of Azure subscriptions from this tenant to a different one. [Learn more](#)

☒ Allow everyone (default)

☐ Permit no one

Subscription entering Microsoft Entra tenant:

This policy controls if users can bring Azure subscriptions from a different Microsoft Entra tenant into this tenant. [Learn more](#)

☒ Allow everyone (default)

☐ Permit no one

Exempted Users

These are special users who can bypass the policy definitions and will always be able to take subscriptions out of this Microsoft Entra ID directory or bring subscriptions into this one.

Search user name or email:



Bonus slide

Enforce MFA to EVERYONE!

MFA is not only for the internal users also for the externals!
Enforce through Conditional Access Policy

–Psssst Pass-keys are coming!! (Preview)

Microsoft Entra Tenant Governance

Entra Tenant Governance is in Public Preview

- Configure Monitoring
- Configure Baseline
- Governance policy

Microsoft Teams

Everyone can message users on Teams to any external domain

Phishing is still a thing within 2026!!



Audit, Audit & Audit - Monitor, Monitor

New access review

[* Review type](#) [* Reviews](#) [Settings](#) [* Review + Create](#)

Configure additional settings, including decision helpers and email notifications.

Upon completion settings

Auto apply results to resource

☐

If reviewers don't respond

Remove access

Action to apply on denied guest users

Block user from signing-in for 30 ...

At end of review, send notification to

Remove user's membership from the resource

Block user from signing-in for 30 days, then remove user from the tenant

Turn on ID Governance guest access

\$0.75 per guest user

Billed monthly

Azure subscription required

Turn on ID Governance guest access to manage your guests with the same premium capabilities as members. Convert guests to governed users, include sponsors in policies, automate guest workflows, and use AI-assisted reviews. [See all benefits](#)

Link subscription

Link an Azure subscription and you will be billed monthly for each unique guest user who has a governance action regardless of the number of actions per user.

Subscription *

Select existing item...

Resource group *

Select existing item...

Billing Unit

Monthly governed users

You will be billed for guest users.



MICROSOFT EMS COMMUNITY

Thank you

aka.ms/M365EMSDiscord

msems.community

Independent and community-run. Not affiliated with, endorsed by, or sponsored by Microsoft. Product names are trademarks of the Microsoft group of companies.

Add the MSEC server tag

1

Open Discord, then your profile

Click your name bottom-left, then Edit Profile.

2

Choose Server Tag

Pick Microsoft EMS Community from the list.

3

Wear it everywhere

The MSEC tag shows next to your name across Discord.

